

BVWA

Beego Vulnerable Web Application

OWASP Top 10:2025 | Versie 3.0 | April 2026

WAARSCHUWING: BVWA is uitsluitend bedoeld voor educatieve doeleinden. Gebruik het NOOIT in productie of op een publiek toegankelijke server. Draai het uitsluitend in een geïsoleerde, lokale testomgeving.

Inhoudsopgave

1. Projectoverzicht & Nieuw in v3.0
2. Installatie & Configuratie
3. Projectstructuur
4. OWASP Top 10:2025 Modules (A01–A10)
5. CTF Modus
6. Login & Dashboard
7. Error Pages
8. Test Credentials
9. Technologieën
10. Disclaimer

1. Projectoverzicht & Nieuw in v3.0

BVWA (Beego Vulnerable Web Application) is een opzettelijk kwetsbare webapplicatie gebouwd met het Go Beego framework, gebaseerd op de OWASP Top 10:2025. Elke module toont een kwetsbare en een veilige implementatie met uitleg via een Info & CWEs knop. Versie 3.0 voegt realistische scenario's, een volledig CTF-systeem en een gestandaardiseerde 'Hulp & Commando's' knop toe aan alle modules.

GitHub: <https://github.com/B2TheEe/BVWA>

Nieuw in versie 3.0:

Feature	Beschrijving
Realistische scenario's	Elk OWASP-module heeft nu een eigen fictiefbedrijfsscenario (bvwa-bank, bvwa-passwd, bvwa-pkg, bvwa-auth, NovaPay etc.)
CTF Modus	10 verborgen flags (een per module). Scoreboard op /ctf, indienen via /ctf/submit. Formaat: BVWA{...}
Hulp & Commando's knop	Alle 19 views hebben nu een uniforme paarse 'Hulp & Commando's' knop met module-specifieke commando's en testdata
Echte Voorbeelden knop	Elke module toont historische incidenten (data-lekken, hacks) passend bij de OWASP-categorie
CLI-interface modules	A03/A04/A06/A07/A08/A09/A10 gebruiken een interactieve terminal-interface waarmee studenten commando's uitvoeren
Uniforme header	Alle modules hebben dezelfde BVWA-header met navigatie
Info & CWEs knop	Elke module heeft een modal met uitleg en alle relevante CWEs
Inject simulatie	SQL injection via in-memory simulatie zonder echte database
Security log terminal	A09 toont live security logs in terminal-stijl
Error pages	Aangepaste 400, 403, 404 en 500 errorpagina's

2. Installatie & Configuratie

Vereisten:

Tool	Versie	Website
Go	1.24+	golang.org
MySQL	5.7+ (optioneel)	mysql.com
Beego	v2.x	beego.vip
bee CLI	v2.x	github.com/beego/bee
bcrypt	golang.org/x/crypto	pkg.go.dev

Installatiestappen:

1	Clone project <code>git clone https://github.com/B2TheEe/BVWA.git</code> <code>cd BVWA</code>
2	Dependencies <code>go mod tidy</code> <code>go get golang.org/x/crypto/bcrypt</code>
3	Bee CLI <code>go install github.com/beego/bee/v2@latest</code>
4	Database (optioneel) <code>mysql -u root -p</code> <code>CREATE DATABASE bvwa;</code>
5	Configureer app.conf Pas <code>db_user</code> , <code>db_pass</code> en <code>db_name</code> aan (optioneel – app draait standaard in-memory)
6	Start app <code>bee run</code>
7	Open browser <code>http://127.0.0.1:8080</code>

conf/app.conf:

```
appname = bvwa  
httpport = 8080  
runmode = dev  
sessionon = true  
sessionname = bvwasession
```

```
db_user = root  
db_pass = jouwwachtwoord  
db_host = 127.0.0.1  
db_port = 3306  
db_name = bvwa
```

3. Projectstructuur

```
bvwa/  
|- conf/app.conf  
|- controllers/  
| |- access_control.go (A01)  
| |- security_misconfig.go(A02)  
| |- supply_chain.go (A03)  
| |- crypto.go (A04)  
| |- injection.go (A05)  
| |- insecure_design.go (A06)  
| |- auth.go (A07)  
| |- integrity.go (A08)  
| |- logging.go (A09)  
| |- exceptions.go (A10)  
| |- ctf.go (CTF Modus)  
| |- home.go (Homepage)  
| |- login.go (Login+Dashboard)  
|- routers/router.go  
|- static/css/bvwa.css  
|- static/js/modal.js  
|- static/js/ctf.js  
|- tests/security.log  
|- main.go  
|- go.mod  
|- security.log  
|- README.md
```

```
|- views/  
| |- home/index.tpl  
| |- admin/dashboard.tpl (A01)  
| |- misconfig/index.tpl (A02)  
| |- misconfig/vulnerable.tpl  
| |- misconfig/secure.tpl  
| |- supplychain/index.tpl (A03)  
| |- supplychain/vulnerable.tpl  
| |- supplychain/secure.tpl  
| |- crypto/index.tpl (A04)  
| |- crypto/vulnerable.tpl  
| |- crypto/secure.tpl  
| |- injection/sql.tpl (A05)  
| |- injection/xss.tpl (A05)  
| |- design/index.tpl (A06)  
| |- design/vulnerable.tpl  
| |- design/secure.tpl  
| |- auth/login.tpl (A07)  
| |- auth/vulnerable.tpl  
| |- auth/secure.tpl  
| |- integrity/index.tpl (A08)  
| |- integrity/vulnerable.tpl  
| |- integrity/secure.tpl  
| |- logging/index.tpl (A09)  
| |- logging/vulnerable.tpl  
| |- logging/secure.tpl  
| |- exceptions/index.tpl (A10)  
| |- exceptions/vulnerable.tpl  
| |- exceptions/secure.tpl  
| |- ctf/index.tpl (CTF Modus)  
| |- login/index.tpl  
| |- login/register.tpl  
| |- login/dashboard.tpl  
| |- errors/400.tpl  
| |- errors/403.tpl  
| |- errors/404.tpl  
| |- errors/500.tpl
```

4. OWASP Top 10:2025 Modules

A01 Broken Access Control

Toegangscontrole wordt niet afgedwongen. Gebruikers kunnen buiten hun bedoelde rechten handelen. Dit module demonstreert IDOR (Insecure Direct Object Reference, CWE-639) via het MegaCorp HR-portaal: medewerkerprofielen zijn opvraagbaar via de `?id=` parameter zonder autorisatiecheck.

Kwetsbaar

Waarom kwetsbaar:

Geen sessie-/rolcontrole. Elke bezoeker heeft directe toegang via URL. Sequentieel ophogen van `?id=` onthult alle profielen inclusief vertrouwelijke HR-notities (salaris, BSN, ziekteverlof).

Veilig

Waarom veilig:

Server-side rolcontrole met `GetSession()`. Fail-closed: geen sessie = redirect naar login. Admins mogen alle profielen zien; gewone gebruikers alleen hun eigen profiel.

Route

Beschrijving

`/admin/vulnerable`

Kwetsbaar — geen autorisatiecheck

`/admin/secure`

Veilig — met sessie- en rolcontrole

A02 Security Misconfiguration

Ontbrekende of verkeerde beveiligingsconfiguratie. 100% van applicaties getroffen. Dit module simuleert een blootgesteld debug-console waarmee shell-commando's worden uitgevoerd en omgevingsvariabelen worden gelekt.

Kwetsbaar

Waarom kwetsbaar:

Geen authenticatie op debug-endpoint. Response headers lekken serverinfo (X-Powered-By, Server). Omgevingsvariabelen zoals `DB_PASSWORD` en `SECRET_KEY` zijn via `'env'` op te vragen. Commando's: `hostname`, `whoami`, `env`, `cat bvwa.conf`, `cat secret.txt`, `ps`, `ifconfig`.

Veilig

Waarom veilig:

Debug-console volledig uitgeschakeld. Vier security-headers per response: `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Content-Security-Policy`, `Strict-Transport-Security`. Geen serverinfo in headers.

Route

Beschrijving

`/misconfig/vulnerable`

Kwetsbaar — blootgesteld debug-console

`/misconfig/secure`

Veilig — security headers, geen debug

A03 Software Supply Chain Failures

Kwetsbaarheden via externe dependencies: niet-geverifieerde packages, kwaadaardige postinstall-hooks. Dit module simuleert `bvwa-pkg`, een fictieve package manager zonder integriteitscontrole.

Kwetsbaar

Veilig

Waarom kwetsbaar: Checksum-verificatie uitgeschakeld (--no-verify). Security-audit overgeslagen (--no-audit). Installatie van bvwa-logger@2.1.3 voert een kwaadaardig postinstall-hook uit die telemetrie leakt inclusief de CTF-flag. Commando's: list, info, install, search, verify (uitgeschakeld), audit (overgeslagen).		Waarom veilig: Checksum-verificatie ingeschakeld: SHA-256 hash van package vergeleken met registry. Gemanipuleerde packages worden geweigerd. Audit toont integriteitsstatus van alle geïnstalleerde packages.	
Route		Beschrijving	
/supplychain/vulnerable		Kwetsbaar — geen checksum verificatie	
/supplychain/secure		Veilig — SHA-256 integriteitscontrole	

A04 Cryptographic Failures			
Zwakke of ontbrekende versleuteling. Vroeger: Sensitive Data Exposure. Dit module simuleert bvwa-passwd, een fictieve credential manager die MD5-hashing en Base64-only tokens gebruikt.			
Kwetsbaar		Veilig	
Waarom kwetsbaar: MD5 voor wachtwoorden: geen salt, deterministisch, triviaal te brute-forcen (50+ miljard/sec op GPU). Base64-only auth-tokens zonder handtekening: payload leesbaar in DevTools. Rainbow table voor veelgebruikte hashes. Commando's: login, hash, crack, token, decode, whoami, users.		Waarom veilig: bcrypt: ingebouwde salt, opzettelijk traag (~100ms), aanpasbare cost factor, timing-safe vergelijking. HMAC-SHA256 gesigneerde tokens: formaat base64_payload.hex_signature. Token-manipulatie detecteerbaar.	
Route		Beschrijving	
/crypto/vulnerable		Kwetsbaar — MD5 + Base64-token	
/crypto/secure		Veilig — bcrypt + HMAC-SHA256	

A05 Injection (SQL & XSS)			
Gebruikersinput als code uitgevoerd. SQL Injection en Cross-Site Scripting. SQL-scenario: MegaCorp Medewerkersdirectory. XSS-scenario: BvwAshop Productzoeker.			
Kwetsbaar		Veilig	
Waarom kwetsbaar: SQL: directe string-concatenatie in query — aanvaller omzeilt WHERE-conditie en krijgt alle records terug. XSS: str2html rendert raw HTML input van gebruiker — script-tags worden uitgevoerd, sessiecookies uitleesbaar.		Waarom veilig: SQL: geparametriseerde queries met ? placeholder — input nooit als SQL uitgevoerd. XSS: Beego escapet automatisch via {{.Variable}} — < wordt <, scripts worden als tekst weergegeven.	
Route		Beschrijving	

/injection/sql/vulnerable	SQL — Kwetsbaar (string concatenatie)
/injection/sql/secure	SQL — Veilig (geparametriseerde query)
/injection/xss/vulnerable	XSS — Kwetsbaar (str2html)
/injection/xss/secure	XSS — Veilig (automatisch escaperen)

A06 Insecure Design

Fundamentele ontwerpfouten in architectuur. Beveiliging moet ingebakken zijn, niet achteraf toegevoegd. Dit module simuleert bvwa-bank: een online overboekingssysteem met een business logic flaw — negatieve bedragen worden zonder validatie verwerkt.

Kwetsbaar

Waarom kwetsbaar:

Geen validatie op het teken van het overboekingsbedrag (CWE-840). Geen overdraft-check (CWE-841). Negatieve bedragen zorgen voor geld dat omgekeerd stroomt. Blootgesteld debug-endpoint op /api/v1/debug. Commando's: balance, transfer, history, accounts.

Veilig

Waarom veilig:

Server-side validatie: bedrag moet > 0 zijn. Overdraft-check voorkomt overboeking boven het saldo. Generieke foutmeldingen. Debug-endpoint uitgeschakeld in veilige versie.

Route	Beschrijving
/design/vulnerable	Kwetsbaar — geen bedragvalidatie (bvwa-bank)
/design/secure	Veilig — bedrag > 0 + overdraft-check
/api/v1/debug	Debug endpoint — intentioneel blootgesteld (A06)

A07 Authentication Failures

Zwakke authenticatie en sessiebeheer. Vroeger: Broken Authentication. Dit module simuleert bvwa-auth, een fictief corporate authentication gateway kwetsbaar voor credential stuffing en brute force.

Kwetsbaar

Waarom kwetsbaar:

Plaintext wachtwoord-vergelijking (CWE-256). User enumeration via verschillende foutmeldingen (CWE-204). Geen rate limiting (CWE-307). Voorspelbare sequentiele sessie-tokens (sess_00042, CWE-330). Commando's: login <user> <pass>, enum <user>, session, help.

Veilig

Waarom veilig:

bcrypt wachtwoord-hashing met MinCost. Rate limiting: max 5 pogingen per IP. Generieke foutmeldingen (geen user enumeration). Cryptografisch willekeurige sessie-tokens. DestroySession() bij login.

Route	Beschrijving
/auth/vulnerable	Kwetsbaar — geen beveiliging (bvwa-auth)
/auth/secure	Veilig — bcrypt + rate limiting

A08 Software/Data Integrity Failures

Geserialiseerde data zonder integriteitscontrole. Omvat insecure deserialization. Dit module simuleert bvwa-deploy, een CI/CD deployment-systeem met aanpasbare deployment-tokens.

Kwetsbaar

Waarom kwetsbaar:

Deployment-tokens zijn Base64-JSON zonder handtekening (CWE-345/CWE-502). Aanvaller kan token decoderen, role:admin instellen, opnieuw encoderen en een geautoriseerde deployment uitvoeren. Commando's: token, decode, encode, deploy.

Veilig

Waarom veilig:

HMAC-SHA256 handtekening op alle tokens.
Token-formaat: base64_payload.hex_signature.
Timing-safe vergelijking via hmac.Equal(). Fail-closed: ongeldige handtekening = deployment geweigerd.

Route

Beschrijving

/integrity/vulnerable

Kwetsbaar — geen handtekening (bvwa-deploy)

/integrity/secure

Veilig — HMAC-SHA256

A09 Security Logging & Alerting Failures

Beveiligingsgebeurtenissen niet gelogd of verkeerd gelogd. Aanvallen blijven onopgemerkt. Dit module simuleert bvwa-auditd, een security audit daemon.

Kwetsbaar

Waarom kwetsbaar:

Wachtwoorden opgeslagen in plaintext in logs (CWE-532). Geen alertering bij brute force-pogingen (CWE-223). Ongesnapede gebruikersinput in logregels (CWE-117). Commando's: view, search, login, alert (nep).

Veilig

Waarom veilig:

Wachtwoorden vervangen door ***REDACTED***.
Brute force-detectie: ALERT na 4 mislukte pogingen van hetzelfde IP. Input gesaniteerd in logs. Correcte log-niveaus: INFO, WARN, ALERT.

Route

Beschrijving

/logging/vulnerable

Kwetsbaar — plaintext wachtwoorden in logs

/logging/secure

Veilig — redacted + brute force alert

A10 Mishandling of Exceptional Conditions

Onjuiste foutafhandeling. 24 gerelateerde CWEs. Fail-open gedrag en info-lekkage. Dit module simuleert NovaPay DiagTool, een fictief fintech diagnostics platform.

Kwetsbaar

Veilig

Waarom kwetsbaar:

Fouten genegeerd met _ (CWE-391). Negatieve bedragen niet gevalideerd. Fail-open bij authenticatie-paniek (CWE-636). Interne database-details gelekt via exception-messages (CWE-209). Commando's: status, check, pay, config, txlog.

Waarom veilig:

Alle fouten afgehandeld. Generieke foutmeldingen naar gebruiker. Fail-closed principe bij elke fout. Interne logging zonder lekkage naar buitenkant. Strikte inputvalidatie op alle bedragen.

Route	Beschrijving
/exceptions/vulnerable	Kwetsbaar — fail-open (NovaPay DiagTool)
/exceptions/secure	Veilig — fail-closed

5. CTF Modus

BVWA heeft een ingebouwd CTF-systeem (Capture The Flag). In elke module is een verborgen flag verstopt. Studenten vinden de flag door de kwetsbare versie te exploiteren. De flags worden ingediend via het scoreboard.

Routes:

Route	Methode	Beschrijving
/ctf	GET	CTF-scoreboard met voortgangsbalk en challenge-overzicht
/ctf/submit	POST	Flag indienen (veld: flag). Redirect naar /ctf na verwerking

Flags & Hints:

Module	Flag	Locatie/Hint
A01	BVWA{1D0R_4cc3ss_2026}	Vraag het admin-profiel op via IDOR — flag staat in de X-CTF-Flag response header
A02	BVWA{M1scC0nf1g_D1r_2026}	Voer 'cat secret.txt' of 'env' uit in de debug-console
A03	BVWA{Supp1y_Ch41n_2026}	Installeer bvwa-logger@2.1.3 — flag verschijnt in de postinstall-telemetrie
A04	BVWA{We4k_3ncrypt10n_2026}	Doe 'token' en vervolgens 'decode' — flag zit in de Base64-payload
A05 SQL	BVWA{SQLi_D1r3ct0ry_2026}	Gebruik payload ' OR '1'='1 — flag staat in het e-mailadres van db_admin
A05 XSS	BVWA{XSS_R3fl3ct3d_2026}	Voer een XSS-payload in — flag staat in de X-CTF-Flag response header
A06	BVWA{N3g4t1ve_Tr4nsf3r_2026}	Gebruik 'transfer NL91ABNA... -500' — negatief bedrag triggert de flag
A07	BVWA{Brute_F0rc3_2026}	Brute force het admin-account — flag verschijnt na succesvolle login
A08	BVWA{1nt3gr1ty_Ch3ck_2026}	Decodeer token, zet role op admin, encodeer opnieuw en voer 'deploy' uit
A09	BVWA{S3ns1t1ve_L0g_2026}	Bekijk de logs via 'view' — flag staat in een logregel met plaintext wachtwoord
A10	BVWA{F41l_0p3n_Exc3pt10n_2026}	Stuur een negatief bedrag via 'pay' — exception leakt de flag

Tip: Alle flags hebben het formaat BVWA{...}. Kijk in HTML-commentaar, response headers (F12 → Network → Response Headers), cookies en log-output.

6. Login & Dashboard

BVWA heeft een volledig login-systeem met sessies. Na succesvol inloggen wordt de gebruiker doorgestuurd naar een dashboard met een overzicht van alle 10 OWASP-modules en de CTF-voortgang.

Route	Beschrijving
/login	Login pagina (GET = formulier, POST = verwerking)
/register	Registratie pagina voor nieuwe gebruikers
/dashboard	Dashboard na inloggen — overzicht alle modules + CTF widget
/logout	Sessie vernietigen en redirect naar /

De /admin/secure route (A01) stuurt niet-geauthenticeerde gebruikers door naar /login. Na inloggen als admin wordt de sessie vernieuwd en de rol 'admin' ingesteld.

7. Error Pages

BVWA heeft aangepaste errorpagina's die consistent zijn met de rest van de applicatie. Ze zijn geregistreerd via `beego.ErrorHandler()` in `main.go`.

Code	Naam	Bestand	Kleur
400	Bad Request	views/errors/400.tpl	Blauw (#3498db)
403	Forbidden	views/errors/403.tpl	Paars (#8e44ad)
404	Not Found	views/errors/404.tpl	Rood (#e74c3c)
500	Internal Server Error	views/errors/500.tpl	Oranje (#e67e22)

De 500-errorpagina bevat een security-notitie die verwijst naar A10 (Mishandling of Exceptional Conditions). De 403-pagina verwijst naar A01 (Broken Access Control).

main.go registratie:

```
beego.ErrorHandler("404", page404)
beego.ErrorHandler("500", page500)
beego.ErrorHandler("403", page403)
beego.ErrorHandler("400", page400)
```

8. Test Credentials

Algemene inloggegevens:

Gebruikersnaam	Wachtwoord	Rol	Gebruik
admin	password123	Administrator	Login, A07, A09
user	user123	Gebruiker	Login (beperkte rechten)

A07-specifieke accounts (bvwa-auth module):

Gebruikersnaam	Wachtwoord	Rol	Gebruik
admin	admin123	admin	A07 kwetsbaar — hoofd-target credential stuffing
support	support	support	A07 kwetsbaar — zwak wachtwoord
backup	backup2026	backup	A07 kwetsbaar — service-account

Deze credentials zijn uitsluitend voor testdoeleinden. Gebruik ze nooit in een productieomgeving.

9. Technologieën

Technologie	Versie	Gebruik
Go	1.24+	Programmeertaal
Beego	v2.x	Web framework (MVC)
MySQL	5.7+ (optioneel)	Database (ORM) — app draait standaard in-memory
bcrypt	golang.org/x/crypto	Wachtwoord hashing (A04, A07)
HMAC-SHA256	crypto/hmac	Data integriteit (A08)
SHA-256	crypto/sha256	Hashing (A03, A04)
bee CLI	v2.x	Development en hot-reload
reportlab	Python	PDF documentatie generatie

10. Disclaimer

BVWA is een educatief project. Het is opzettelijk kwetsbaar gebouwd om beveiligingsconcepten te demonstreren. Het gebruik van BVWA buiten een geïsoleerde testomgeving is uitdrukkelijk verboden. De auteurs aanvaarden geen enkele verantwoordelijkheid voor schade of misbruik voortvloeiend uit dit project. Gebruik altijd verantwoord en ethisch — uitsluitend op systemen waarvoor je toestemming hebt.